

Fictional Banking App — User Stories (v1)

Scope: A consumer banking web/mobile app with **Login**, **Customer Management**, and a **Private Zone** that covers **Balance management**, **Withdrawals**, and **Money Transfers**. Stories are grouped by epic and phrased in the standard "As a <role>, I want <capability> so that <benefit>" format with concise acceptance criteria.

Personas (Glossary)

- **Customer** — Registered retail banking user.
- **Admin** — Bank administrator with full back-office privileges.
- **CSR** — Customer Support Representative with controlled back-office privileges.
- **System** — Automated back-end processes.

Priority legend: **M** (Must), **S** (Should), **C** (Could)

EPIC A — Authentication & Access Control

AUTH-01 (M) — *Customer login* - As a **Customer**, I want to log in with my username/email and password so that I can access my accounts. - **Acceptance** - Given a valid account, when I enter correct credentials, **Then** I am signed in and redirected to the dashboard. - When credentials are invalid, **Then** I see a clear error and remain on login. - Passwords are never echoed; rate limits apply to repeated failures.

AUTH-02 (M) — *Two-factor authentication (2FA)* - As a **Customer**, I want optional/required 2FA (SMS, authenticator app) so that my account is protected. - **Acceptance** - If 2FA is enabled/required, **Then** login prompts for a 2FA code after password. - 2FA failures do not reveal whether password was correct. - Backup codes can be generated and revoked.

AUTH-03 (M) — *Forgot password* - As a **Customer**, I want to reset my password securely so that I can regain access. - **Acceptance** - I can request a reset via email/SMS with time-limited token. - New password must meet policy; all sessions are revoked on reset.

AUTH-04 (M) — *Logout & session timeout* - As a **Customer**, I want to log out and have idle sessions expire so that my account stays safe. - **Acceptance** - Manual logout ends the session across devices if chosen. - Idle sessions auto-expire after configurable inactivity.

AUTH-05 (M) — *Account lockout* - As a **System**, I need to temporarily lock accounts on repeated failed logins so that brute force is mitigated. - **Acceptance** - After N failed attempts, the account is locked for a cooling-off period (or until CSR unlocks).

AUTH-06 (S) — *Device recognition* - As a **Customer**, I want to trust a device so that 2FA prompts are reduced on known devices. - **Acceptance** - I can view and revoke trusted devices in settings.

AUTH-07 (S) — *View & revoke active sessions* - As a **Customer**, I want to see active sessions so that I can revoke suspicious ones. - **Acceptance** - List shows device, location approximation, and last activity; I can revoke any session.

AUTH-08 (S) — *CAPTCHA on risk* - As a **System**, I want to present CAPTCHA when risk signals are high so that automated abuse is limited.

AUTH-09 (S) — *Terms & privacy consent* - As a **Customer**, I want to accept terms/privacy updates so that I use the app compliantly.

EPIC B — Customer Management (Back Office)

CUST-01 (M) — *Create customer* - As an **Admin**, I want to create a customer record so that onboarding can begin. - **Acceptance** - Required fields validated; unique identifiers enforced; audit entry created.

CUST-02 (M) — *Search customers* - As a **CSR**, I want to search by name, phone, email, and ID so that I can find customers fast.

CUST-03 (M) — *View customer profile* - As a **CSR**, I want a consolidated profile (KYC status, accounts, limits) so that I can assist effectively.

CUST-04 (M) — *Update profile* - As a **CSR**, I want to update contact info with verification so that records stay accurate.

CUST-05 (M) — *Enable/disable customer* - As an **Admin**, I want to suspend or re-enable access so that I can manage risk and compliance.

CUST-06 (M) — *Assign roles & entitlements* - As an **Admin**, I want to grant CSR/Admin roles and account entitlements so that least-privilege is enforced.

CUST-07 (M) — *Link/unlink accounts* - As a **CSR**, I want to link deposit/credit accounts to a customer so that they appear in the private zone.

CUST-08 (S) — *Set limits* - As an **Admin**, I want to configure per-customer transfer/withdrawal limits so that exposure is controlled.

CUST-09 (S) — *Reset credentials* - As a **CSR**, I want to trigger a secure password reset so that locked-out customers can regain access.

CUST-10 (S) — *KYC/AML status tracking* - As an **Admin**, I want to record verification status and flags so that compliance is traceable.

CUST-11 (S) — *Freeze specific account* - As a **CSR**, I want to freeze a suspicious account while leaving others active so that investigations proceed safely.

CUST-12 (C) — *Data export (subject access)* - As a **Customer**, I want to request my data export so that I can exercise privacy rights.

EPIC C — Accounts & Balance (Private Zone)

ACCT-01 (M) — *View accounts overview* - As a **Customer**, I want to see all my accounts with **Available** vs **Ledger** balance so that I understand funds.

ACCT-02 (M) — *Transaction history* - As a **Customer**, I want to view transactions with date/type/amount/balance impact so that I can reconcile activity. - **Acceptance** - Supports paging, basic filters (date range, amount, type), and search by description/reference.

ACCT-03 (M) — *Pending holds* - As a **Customer**, I want to see pending/hold amounts so that I know why available balance differs.

ACCT-04 (M) — *Account details* - As a **Customer**, I want to view IBAN/account number, routing/BIC, and product info so that I can receive funds.

ACCT-05 (S) — *Download statements* - As a **Customer**, I want to export PDF/CSV statements for a period so that I can share with third parties.

ACCT-06 (S) — *Multi-currency support* - As a **Customer**, I want to view balances in the account currency and a selected display currency so that I compare value.

ACCT-07 (S) — *Account nicknames* - As a **Customer**, I want to rename accounts (e.g., "Savings — Travel") so that I identify them quickly.

ACCT-08 (S) — *Fees & interest transparency* - As a **Customer**, I want fees/interest lines clearly labeled so that costs/earnings are obvious.

ACCT-09 (C) — *Statement delivery preferences* - As a **Customer**, I want e-statement opt-in/out and delivery channel selection so that I control notifications.

ACCT-10 (C) — *Dispute a transaction (initiate)* - As a **Customer**, I want to flag a transaction for dispute so that support can investigate.

EPIC D — Withdrawals

Note: "Withdrawal" in the app is modeled as **cardless ATM cash withdrawal** via one-time codes. Transfers to external accounts are covered in EPIC E.

WD-01 (M) — *Initiate cardless cash withdrawal* - As a **Customer**, I want to generate a one-time ATM code for a chosen account and amount so that I can withdraw cash. - **Acceptance** - Amount must be within available balance and daily limit. - Code is time-limited and masked in UI; full code shown once.

WD-02 (M) — *2FA confirmation* - As a **Customer**, I want to confirm withdrawal creation with 2FA so that unauthorized cash-outs are prevented.

WD-03 (M) — *Cancel unused code* - As a **Customer**, I want to cancel an unused withdrawal code so that funds are released back immediately.

WD-04 (S) — *Withdrawal history* - As a **Customer**, I want to view past withdrawals with status (Used/Expired/Cancelled) so that I can track cash-outs.

WD-05 (S) — *Limit management visibility* - As a **Customer**, I want to see my remaining daily/monthly withdrawal limits so that I can plan ahead.

WD-06 (C) — *Notifications* - As a **Customer**, I want alerts on code creation/usage/expiry so that I'm aware of cash activity.

EPIC E — Money Transfers

XFER-01 (M) — *Transfer between own accounts* - As a **Customer**, I want to move funds between my accounts instantly so that I can manage cash.

XFER-02 (M) — *Add beneficiary (internal)* - As a **Customer**, I want to save another customer of the same bank as a beneficiary so that future payments are faster.

XFER-03 (M) — *Add beneficiary (interbank/IBAN)* - As a **Customer**, I want to save an external IBAN/BIC beneficiary so that I can send money outside the bank.

XFER-04 (M) — *One-time transfer to new beneficiary* - As a **Customer**, I want to send a one-off payment to a new beneficiary with step-up 2FA so that fraud is reduced.

XFER-05 (M) — *Confirm & execute transfer* - As a **Customer**, I want to see fees, exchange rate (if any), and a final confirmation so that I know costs before sending.

XFER-06 (M) — *Transfer limits enforcement* - As a **System**, I need to enforce per-transaction and daily/rolling limits so that exposure is controlled.

XFER-07 (S) — *Schedule future-dated transfer* - As a **Customer**, I want to set a date/time for a transfer so that bills are paid on time.

XFER-08 (S) — *Recurring transfers* - As a **Customer**, I want to set recurring schedules (weekly/monthly/custom) so that I can automate payments.

XFER-09 (S) — *Track transfer status* - As a **Customer**, I want to see In-Progress/Completed/Failed with references so that I can follow up when needed.

XFER-10 (S) — *Cancel pending transfer* - As a **Customer**, I want to cancel a transfer that's not yet processed so that I can correct mistakes.

XFER-11 (S) — *Proof of payment receipt* - As a **Customer**, I want a downloadable/shareable receipt so that I can prove payment.

XFER-12 (C) — *Templates and favorites* - As a **Customer**, I want to create templates and mark favorites so that frequent payments are quick.

XFER-13 (C) — *International transfer* - As a **Customer**, I want to send cross-border payments with currency selection and rate preview so that I can pay globally.

XFER-14 (C) — *Beneficiary verification* - As a **System**, I want to validate beneficiary details (checksum/format and optional micro-verification) so that bounce rates are reduced.

EPIC F — Private Zone: Settings & Profile

PZ-01 (M) — *Update personal info* - As a **Customer**, I want to update my address, phone, and email with verification so that my contact details stay current.

PZ-02 (M) — *Change password* - As a **Customer**, I want to change my password so that I can maintain security.

PZ-03 (S) — *Manage 2FA methods* - As a **Customer**, I want to enable/disable 2FA methods and regenerate backup codes so that I control my security.

PZ-04 (S) — *Notification preferences* - As a **Customer**, I want to configure alerts (channels and thresholds) so that I receive only what matters.

PZ-05 (S) — *Devices & sessions* - As a **Customer**, I want to review devices/sessions and revoke any so that I keep my account safe.

PZ-06 (C) — *Close account request* - As a **Customer**, I want to request account closure with disclosures so that I can exit the bank if desired.

PZ-07 (C) — *Language & accessibility* - As a **Customer**, I want to set language and accessibility options (text size, contrast) so that the app is usable to me.

EPIC G — Security, Fraud & Compliance

SEC-01 (M) — *Audit logging* - As an **Admin**, I want immutable audit logs for auth, profile changes, limits, transfers, and withdrawals so that investigations are possible.

SEC-02 (M) — *Risk-based controls* - As a **System**, I want step-up 2FA and holds when risk signals trigger so that fraud is reduced.

SEC-03 (M) — *Privacy consent & data retention* - As a **Compliance Officer**, I want recorded privacy consent and retention policies so that we meet regulatory requirements.

SEC-04 (M) — *RBAC enforcement* - As a **System**, I want role-based access control so that users only see what they're permitted to see.

SEC-05 (S) — *Rate limiting & IP throttling* - As a **System**, I want adaptive rate limits so that abuse is constrained without harming legitimate users.

SEC-06 (S) — *Session revocation on critical changes* - As a **System**, I want to revoke all sessions when password/2FA changes so that compromised sessions are cut off.

SEC-07 (C) — *Exportable compliance reports* - As an **Admin**, I want to export activity and limit-breach reports so that audits are streamlined.

SEC-08 (C) — *PII masking* - As a **System**, I want to mask sensitive fields in UI and logs so that data leakage risk is minimized.

EPIC H — Notifications & Messaging

NTF-01 (M) — *Login alerts* - As a **Customer**, I want alerts on new device logins so that I can detect account takeover early.

NTF-02 (M) — *Transfer and withdrawal alerts* - As a **Customer**, I want success/failure alerts for transfers and cash withdrawals so that I track money movement.

NTF-03 (S) — *Threshold-based alerts* - As a **Customer**, I want alerts when transactions exceed a threshold so that I monitor high-value activity.

NTF-04 (S) — *In-app message center* - As a **Customer**, I want a message inbox for bank notices so that I can read and archive communications.

NTF-05 (C) — *Channel preferences* - As a **Customer**, I want to choose email/SMS/push per alert type so that I control noise.

NTF-06 (C) — *Digest mode* - As a **Customer**, I want daily/weekly digests so that I reduce alert fatigue.

EPIC I — Operations & Observability (Back Office)

OPS-01 (M) — *Health overview* - As an **Admin**, I want a simple health dashboard (uptime, latency, error rate) so that I can detect incidents.

OPS-02 (S) — *Export reports* - As an **Admin**, I want exportable transfer/withdrawal volume reports so that finance can reconcile.

OPS-03 (S) — *Maintenance mode banner* - As a **System**, I want to display scheduled-maintenance banners so that customers are informed.

OPS-04 (C) — *Manual reversal workflow* - As a **CSR**, I want a controlled reversal process with approvals so that I can fix operational errors.

OPS-05 (C) — *Anomaly alerts to ops* - As a **System**, I want to alert ops on spikes in failed logins or transfers so that they can respond fast.

Non-Functional Requirements (expressed as user-oriented outcomes)

NFR-01 (M) — *Performance* - As a **Customer**, I want the dashboard to load in < 2 seconds at p95 so that the app feels responsive.

NFR-02 (M) — *Availability* - As a **Customer**, I want 99.9% monthly availability so that I can bank reliably.

NFR-03 (M) — *Security posture* - As a **Compliance Officer**, I want encryption in transit and at rest, secret rotation, and regular pen-tests so that risk is managed.

NFR-04 (S) — *Accessibility* - As a **Customer**, I want WCAG 2.1 AA support (keyboard nav, contrast, screen readers) so that the app is inclusive.

NFR-05 (S) — *Localization* - As a **Customer**, I want multi-language support and locale-aware formats so that content matches my region.

NFR-06 (C) — *Scalability* - As a **System**, I want to scale to peak concurrent users without degraded p95 latency so that growth is supported.

Assumptions & Out of Scope (v1)

- Self-registration is **out of scope**; onboarding is back-office initiated (CUST-01).
- ATM network integration exists for cardless cash (WD-01) and provides status webhooks.

- Interbank transfers use existing rails (e.g., SEPA/SWIFT/Faster Payments) with bank-provided cut-off times.
 - Credit/loan products and bill-pay are out of scope for v1.
-

Tracer (Release Cut Suggestion)

- **MVP:** AUTH-01..05, CUST-01..05, ACCT-01..05, WD-01..03, XFER-01..06, PZ-01..02, SEC-01..04, NTF-01..02, NFR-01..03.
 - **Post-MVP:** remaining S items; **Stretch:** remaining C items.
-

End of v1